The Case of the Stolen Szechuan Sauce

Summary

This is a DFIR CTF Rick and Morty-themed scenario provided by James Smith at dfirmadness.com. DFIRMadness provides the scenario, mocked disk images and other relevant files, and questions to answer.

Your bedroom door bursts open, shattering your pleasant dreams. Your mad scientist of a boss begins dragging you out of bed by the ankle. He simultaneously explains between belches that the FBI contacted him. They found his recently-developed Szechuan sauce recipe on the dark web. As you careen past the door frame you are able to grab your incident response “Go-Bag”. Inside is your trusty incident thumb drive and laptop.

Files Provided

- DC01 Disk Image (EO1)
- DC01 Memory and PageFile
- DC01 Autoruns
- DC01 Protected Files
- Case001 PCAP
- Desktop Disk Image (E01)
- Desktop Memory and PageFile
- Desktop Autoruns
- Desktop Protected Files

https://dfirmadness.com/the-stolen-szechuan-sauce/

System Identification

- What’s the Operating System of the Server?
    - Windows Server 2012 R2 Standard Evaluation

```
E:\Tools\RegRipper3.0-master>rip.exe -r "D:\Cases\DFIRMadness\THE CASE OF THE STOLEN SZECHUAN SAUCE\DC01\Protected\software" -p winver
Launching winver v.20200525
winver v.20200525
(Software) Get Windows version & build info

ProductName                 Windows Server 2012 R2 Standard Evaluation
BuildLab                    9600.winblue_gdr.140221-1952
BuildLabEx                  9600.17031.amd64fre.winblue_gdr.140221-1952
RegisteredOrganization
RegisteredOwner             Windows User
InstallDate                 2020-09-17 16:43:59Z
```

- What’s the Operating System of the Desktop?
    - Windows 10 Enterprise Evaluation

```
E:\Tools\RegRipper3.0-master>rip.exe -r "D:\Cases\DFIRMadness\THE CASE OF THE STOLEN SZECHUAN SAUCE\Desktop\Protected Files\software" -p winver
Launching winver v.20200525
winver v.20200525
(Software) Get Windows version & build info

ProductName               Windows 10 Enterprise Evaluation
ReleaseID                 2004
BuildLab                  19041.vb_release.191206-1406
BuildLabEx                19041.1.amd64fre.vb_release.191206-1406
CompositionEditionID      EnterpriseEval
RegisteredOrganization
RegisteredOwner           Admin
UBR                       264
InstallDate               2020-09-18 05:47:03Z
InstallTime               2020-09-18 05:47:03Z
UBR                       264
```

- What was the local time of the Server?
  - Pacific Standard Time

```
E:\Tools\RegRipper3.0-master>rip.exe -r "D:\Cases\DFIRMadness\THE CASE OF THE STOLEN SZECHUAN SAUCE\DC01\Protected\system" -p timezone
Launching timezone v.20200518
timezone v.20200518
(System) Get TimeZoneInformation key contents

TimeZoneInformation key
ControlSet001\Control\TimeZoneInformation
LastWrite Time 2020-09-17 17:56:13Z
  DaylightName   -> @tzres.dll,-211
  StandardName   -> @tzres.dll,-212
  Bias           -> 480 (8 hours)
  ActiveTimeBias -> 420 (7 hours)
  TimeZoneKeyName-> Pacific Standard Time
```

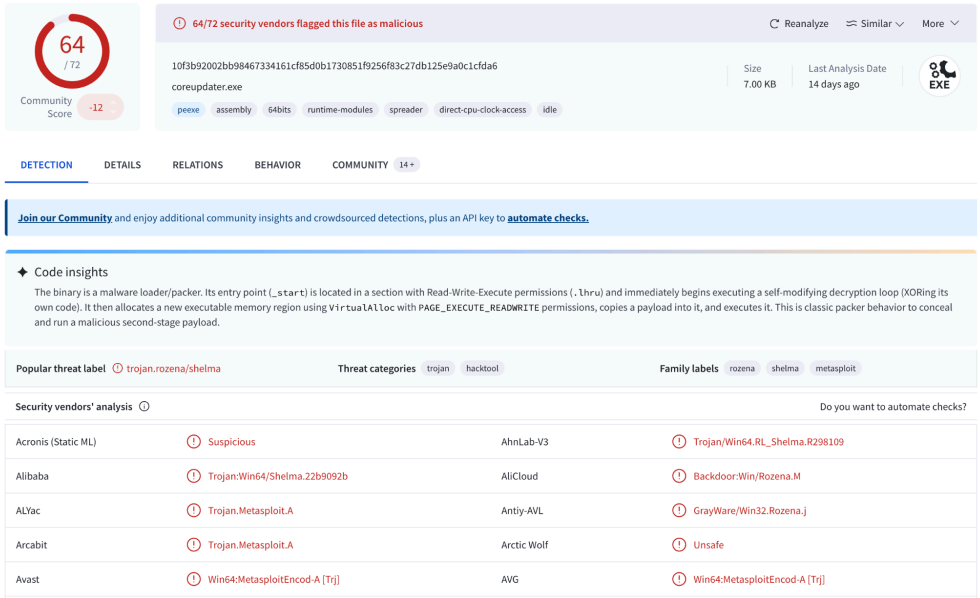
Breach Assessment

- Was there a breach?
  - Yes, there was a login from external IP 194.61.24.102 to CITADEL-DC01 at 9/19/20 2:21 as the Administrator user.
  - LogonId: 0x510986

- What was the initial entry vector (how did they get in)?
  - The entry vector was RDP (Remote Desktop Protocol) as shown through the type 10 logon.
  - LogonId: 0x510986

Malware Analysis

- Was malware used? If so, what was it?
  - coreupdater.exe is flagged as a Metasploit Trojan by VirusTotal



- What process was malicious?
  - coreupdater.exe

- Identify the IP Address that delivered the payload.
  - 194.61.24[.]102

Browser History

URL	Visit Time	Visit Count	Web Browser	User Profile	URL Length
http://194.61.24[.]102/	9/19/2020 3:23	2	Internet Explorer 10/11 / Edge	Administrator	21

- What IP Address is the malware calling to?
  - 203.78.103[.]109

- Where is this malware on disk?
  - C:\Windows\System32\coreupdater.exe
  - Event Log [7045 / 0x1b85] ['coreupdater' 'C:\\Windows\\System32\\coreupdater.exe' 'user mode service' 'auto start' 'LocalSystem']

- When did it first appear?
  - 9/19/20 2:24

    - $MFT File reference: 87137-2

- Did someone move it?
    - No evidence of this.

- What were the capabilities of this malware?
    - Creates an interactive shell back to C2 server

- Is this malware easily obtained?
    - Metasploit framework is open source and payloads can be created by anyone.

- Was this malware installed with persistence on any machine?

TIme	Machine	Method
9/19/2020 2:27:49 AM	Domain Controller	Service
9/19/2020 2:30:01 AM	Domain Controller	RunKey
9/19/2020 2:40:49 AM	Desktop	Service
9/19/2020 2:44:03 AM	Desktop	RunKey

Malicious Infrastructure

- What malicious IP Addresses were involved?
- Were any IP Addresses from known adversary infrastructure?
- Are these pieces of adversary infrastructure involved in other attacks around the time of the attack?

Both IPs were flagged as connected to malware during the 2020 timeframe.

IP	Description	Virus Total
194.61.24[.]102	Initial RDP connection and payload.	https://www.virustotal.com/gui/ip-address/194.61.24.102?nocache=1
203.78.103[.]109	C2 Server	https://www.virustotal.com/gui/ip-address/203.78.103.109

Lateral Movement

- Did the attacker access any other systems?
    - How?

        - The attacker was able to login as the Administrator user on the domain controller which allowed automatic authentication over Kerberos when RDP was initiated to Desktop. No credential entry was needed.
    - When?
        - 9/19/2020 2:35:55 AM

- Did the attacker steal or access any data?

Machine	Path	Files	Access Time	Archive Creation Time	Archive Name
Domain Controller	C:/FileShare/Secret/	• NoJerry.tx • PortalGunPlans.txt • SECRET_beth.txt • Szechuan Sauce.txt	9/19/20 2:31	9/19/20 2:32	secret.zip
Desktop	C:\Users\mortysmith\Documents	• Portal_gun.png • Plans.txt • My Social Security Number.txt	9/19/20 2:45	9/19/20 2:46	loot.zip

Network Architecture

- What was the network layout of the victim network?
    - The domain controller was exposed to the internet which allowed the attacker to gain access.
- What architecture changes should be made immediately?
    - The domain controller should be inside the internal network and only accessed from the outside through a VPN.

Theft

- Did the attacker steal the Szechuan sauce?
    - It should be assumed the attacker stole the recipe due to the file being accessed at 2:31 and an archive created at 2:32.

- Did the attacker steal or access any other sensitive files?

Machine	Path	Files	Access Time	Archive Creation Time	Archive Name

Domain Controller	C:/FileShare/Secret/	• NoJerry.tx • PortalGunPlans.txt • SECRET_beth.txt • Szechuan Sauce.txt	9/19/20 2:31	9/19/20 2:32	secret.zip
Desktop	C:\Users\mortysmith\Documents	• Portal_gun.png • Plans.txt • My Social Security Number.txt	9/19/20 2:45	9/19/20 2:46	loot.zip

- Finally, when was the last known contact with the adversary?
    - PCAP shows last connection to 203.78.103[.]109 at 9/19/20 5:38.

Advanced Questions

- What CIS Top 20 or SANS Top 20 Controls would have directly prevented this breach?
    - CIS Control 5: Account Management
        - Improving password requirements would have made it more difficult for attackers to brute force RDP as Administrator.
    - CIS Control 9: Email and Web Browser Protections
        - Coreupdater.exe was downloaded over a browser so disabling downloads from unapproved websites would have prevented vector.
    - CIS Control 10: Malware Defenses
        - All executables should be approved by the security team as well as having endpoint security software to scan and identify suspicious processes.
    - CIS Control 12: Network Infrastructure Management
        - Reviewing the network infrastructure would have revealed that exposing the domain controller to the internet is high risk and bad practice and prevented direct external access.
- What major architecture improvement could have prevented this breach?
    - The domain controller should be inside the internal network and only accessed from the outside through a VPN. It should not be exposed to the external internet.
- Can you identify policy improvements or controls that should be implemented to secure this environment?
    - Password Complexity Policy
        - More complex password requirements would increase difficulty for brute force.
    - Browser and Executable Limitation Control
        - Preventing downloads from unapproved sites and execution of unknown files should be disabled.
    - Account Lock Policy

        - Locking user accounts after 5 attempts within a short time would prevent brute force attack
- Which users have actually logged onto the DC?
    - Human Logon Users
        - Administrator
        - mortysmith
        - Ricksanchez

```
chainsaw search -e 4624 Security.evtx > dc_logon.txt

grep TargetUserName dc_logon.txt | sort | uniq
TargetUserName: ANONYMOUS LOGON
TargetUserName: Administrator
TargetUserName: CITADEL-DC01$
TargetUserName: DESKTOP-SDN1RPT$
TargetUserName: DWM-1
TargetUserName: DWM-2
TargetUserName: DWM-3
TargetUserName: LOCAL SERVICE
TargetUserName: NETWORK SERVICE
TargetUserName: SYSTEM
TargetUserName: WIN-E0PO207ERMD$
TargetUserName: mortysmith
TargetUserName: ricksanchez
```

- Which users have actually logged onto the Desktop machine?
    - Admin
    - Administrator
    - mortysmith
    - ricksanchez

```
rip.exe -r SAM -p samparse

Username        : Admin [1001]
SID             : S-1-5-21-41211245-796119838-3940169921-1001
Full Name       :
User Comment    :
Account Type    :
Account Created : Fri Sep 18 05:49:07 2020 Z
Security Questions:
Question 1  : What was your first pets name?
Answer 1    : snowball
Question 2  : What was your childhood nickname?
```

```
Answer 2    : rick
Question 3  : Whats the first name of your oldest cousin?
Answer 3    : bill
Name            :
Last Login Date : Sat Sep 19 03:15:57 2020 Z
Pwd Reset Date  : Fri Sep 18 05:49:07 2020 Z
Pwd Fail Date   : Never
Login Count     : 6
--> Password does not expire
--> Password not required
--> Normal user account
```

```
grep TargetUserName desktop_logon.txt | sort | uniq

TargetUserName: Admin
TargetUserName: Administrator
TargetUserName: DESKTOP-SDN1RPT$
TargetUserName: DWM-1
TargetUserName: DWM-2
TargetUserName: DWM-3
TargetUserName: LOCAL SERVICE
TargetUserName: NETWORK SERVICE
TargetUserName: SYSTEM
TargetUserName: UMFD-0
TargetUserName: UMFD-1
TargetUserName: UMFD-2
TargetUserName: UMFD-3
TargetUserName: defaultuser0
TargetUserName: mortysmith
TargetUserName: ricksanchez
```

- What are the passwords for the users in the domain?

```
impacket-secretsdump -ntds ntds.dit -system SYSTEM LOCAL

Administrator:500:aad3b435b51404eeaad3b435b51404ee:10e63d3f2c9924bae49241cf
f847e405:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0
:::
CITADEL-DC01$:1001:aad3b435b51404eeaad3b435b51404ee:33c082748b7d35ec846a513
b7be92d94:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:25c9610b742a5bca9aa3801c08b8ca4
```

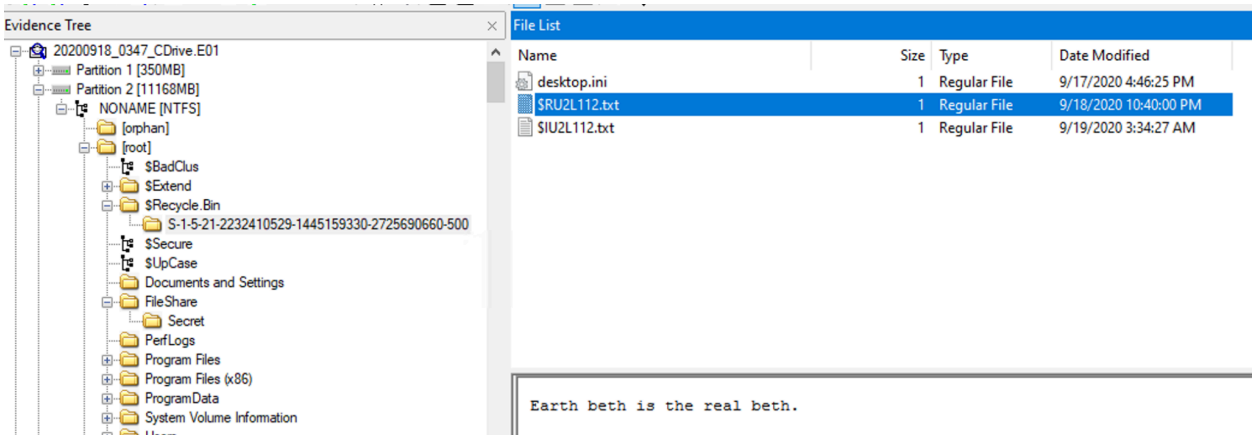
```
e:::
C137.local\jerrysmith:1104:aad3b435b51404eeaad3b435b51404ee:bc51f858ccacc9d
b408c0ba511d5d639:::
C137.local\summersmith:1105:aad3b435b51404eeaad3b435b51404ee:26b2cc706093c4
fa46e0519ec5feaeaf:::
C137.local\ricksanchez:1106:aad3b435b51404eeaad3b435b51404ee:746447f27820a9
d863eea94d176cc135:::
C137.local\mortysmith:1108:aad3b435b51404eeaad3b435b51404ee:dc8b282b8f4e1dd
3c5f95fd491ff6d8d:::
C137.local\bethsmith:1109:aad3b435b51404eeaad3b435b51404ee:b9cc9177094af2e1
7b413a0cbf63fac2:::
C137.local\birdman:1118:aad3b435b51404eeaad3b435b51404ee:944055b77ebe7d6fd8
0f24b5fce634fb:::
DESKTOP-SDN1RPT$:1602:aad3b435b51404eeaad3b435b51404ee:fa6ecdc900cbeeb623cf
c92297e5b653:::
```

Passwords

Username	NTLM Hash	Cracked Password	Cracking Method
Administrator	10e63d3f2c9924bae49241cff847e405	)&Denver89	CrackStation
Guest	31d6cfe0d16ae931b73c59d7e0c089c0	(Empty Password)	N/A
CITADEL-DC01$	33c082748b7d35ec846a513b7be92d94	Not found	
DESKTOP-SDN1RPT$	25c9610b742a5bca9aa3801c08b8ca4e	Not found	
mortysmith	bc51f858ccacc9db408c0ba511d5d639	!BETHEYBOO12!	CrackStation
WIN-E0PO207ERMD$	26b2cc706093c4fa46e0519ec5feaeaf	Not found	
SYSTEM	746447f27820a9d863eea94d176cc135	Not found	
ricksanchez	dc8b282b8f4e1dd3c5f95fd491ff6d8d	Jessica@1	CrackStation
LOCAL SERVICE	b9cc9177094af2e17b413a0cbf63fac2	RedWine1!	CrackStation
NETWORK SERVICE	944055b77ebe7d6fd80f24b5fce634fb	(dimension5150)	CrackStation

- Can you recover the original file about Beth's Secrets?
  - What was the original name?
    - C:\FileShare\Secret\SECRET_beth.txt
  - Original contents?
    - Earth beth is the real beth.

Original file SECRET_beth.txt was sent to Recycle Bin. The attacker created a file Beth_Secret.txt with content “Space Beth is the real Beth”.



- Finally, what file was time-stomped?
  - C:\FileShare\Secret\Beth_Secret.txt is the time-stomped file. The SI (Standard Information) times are able to be changed by the attacker but FN (File Name) times are much harder. The below table shows a discrepancy between the SI and FN times where the FN times are during the attack while the SI times are backdated to the previous day. This was an attempt by the attacker to hide their tracks of adding a new, similar file to be mistaken for the one they deleted.

Field	$SI (0x10)	$FN (0x30)
Created	9/18 10:33 PM	9/19 2:34 AM
Modified	9/18 10:35 PM	9/19 2:34 AM
Record Change	9/18 10:35 PM	9/19 2:34 AM

Timeline

Date/Time (Local)	System	Event	Details	Source
9/19/2020 2:19 AM	DC01	Reconnaissance	External IP 194.61.24[.]102 begins scanning (RDP exposed)	PCAP
9/19/2020 2:21 AM	DC01	Initial Access	Successful RDP logon (Logon Type 10) as Administrator	Security Log (Event ID 4624)
9/19/2020 2:23 AM	DC01	Malware Activity	Browser connection to attacker IP 194.61.24[.]102	Browser History

9/19/2020 2:24 AM	DC01	Malware Execution	coreupdater.exe first observed on disk	$MFT
9/19/2020 2:27:49 AM	DC01	Persistence	Malicious service installed (coreupdater)	Event Log 7045
9/19/2020 2:30:01 AM	DC01	Persistence	Run key added for persistence	Registry
9/19/2020 2:31 AM	DC01	Data Access	Sensitive files accessed	File System
9/19/2020 2:32 AM	DC01	Data Staging	secret.zip archive created	File System
9/19/2020 2:34 AM	DC01	Data Manipulation	Beth_Secret.txt created and timestomped	$MFT ($SI vs $FN)
9/19/2020 2:35:55 AM	Desktop	Lateral Movement	RDP access to Desktop using existing Administrator session	Security Logs
9/19/2020 2:40:49 AM	Desktop	Persistence	Malicious service installed	Event Log
9/19/2020 2:44:03 AM	Desktop	Persistence	Run key added	Registry
9/19/2020 2:45 AM	Desktop	Data Access	Sensitive user files accessed	File System
9/19/2020 2:46 AM	Desktop	Data Staging	loot.zip archive created	File System
9/19/2020 5:38 AM	Network	C2 Communication	Last known communication with 203.78.103[.]109	PCAP